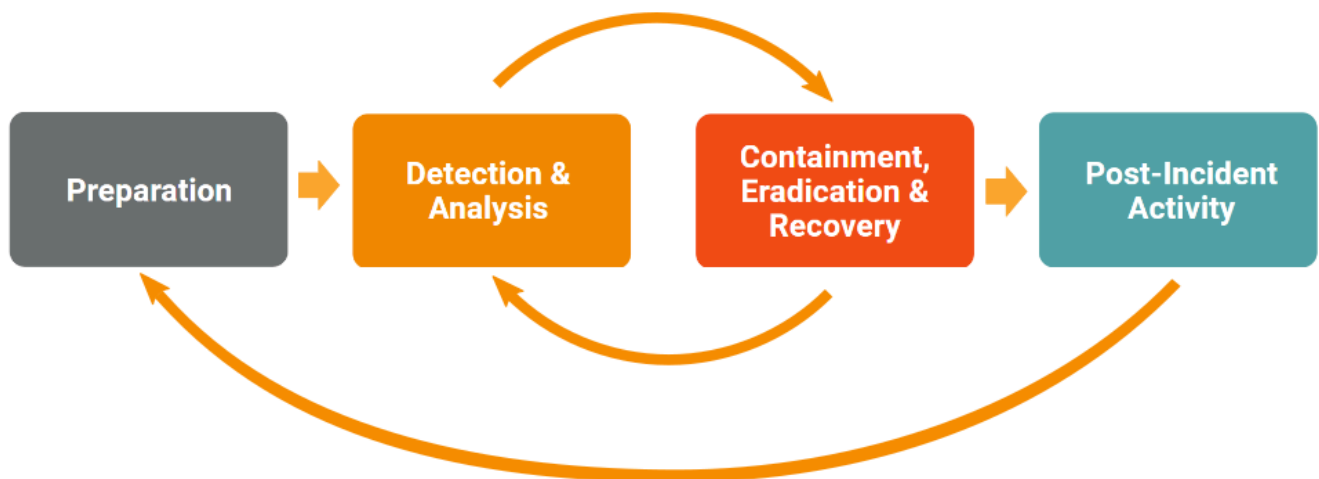


Network Bruteforce Incident Response Playbook

The Lumu Network Bruteforce Incident Response Playbook is based on the Computer Security Incident Handling Guide by the National Institute of Standards and Technology (NIST). According to NIST special publication [800-61](#), the incident response life cycle has four main phases, as described in the following illustration.



This document contains guidelines for Network brute force incident response using Lumu. Consider this playbook as a guideline to improve the effectiveness of the incident response and adapt it according to your specific requirements.

What are Network Bruteforce Incidents?

Lumu is capable of detecting Network bruteforce activity from devices associated with your organization. Network bruteforce incidents are a pattern of **high-volume, repetitive connection attempts** from a source endpoint to a specific service running on a destination endpoint that happen within a short period of time. Unlike account level incidents, network bruteforce detections rely on NetFlow metadata which allows early detection of suspicious behavior. By identifying Network bruteforce incidents, Lumu helps your organization **gain insight** into:

- Attacks that aim to identify valid credentials, open services, and escalate access or move laterally within the network of your organization.
- Misconfigurations within the network that can produce patterns similar to bruteforce attacks. Such behavior could lead to the disruption and denial of internal services.

The metadata used to identify this type of incidents is:

- Source and destination IP
- Destination Port
- Number of packages
- Number of connection attempts

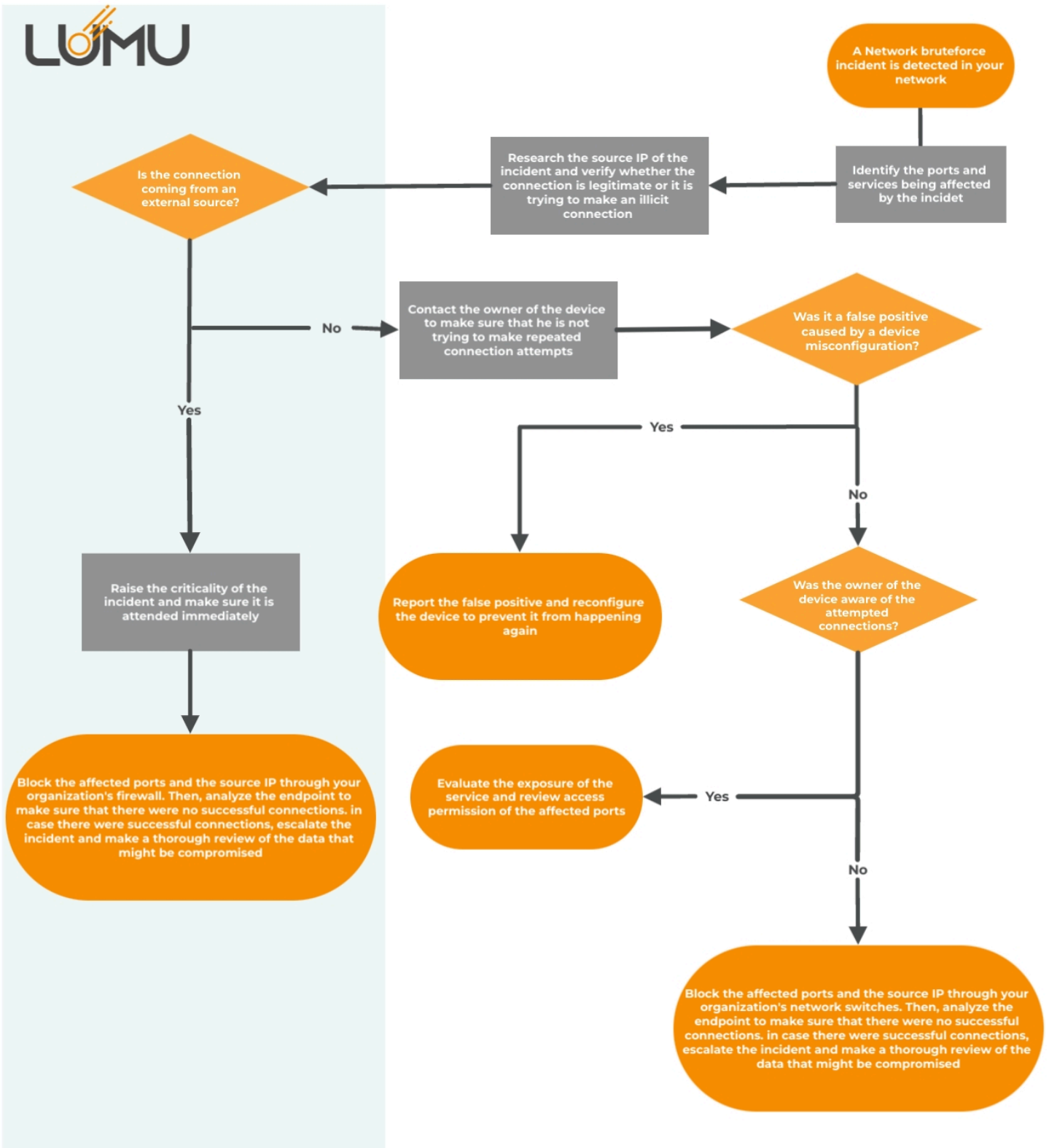
These types of attacks aim to identify valid credentials, open services, and escalate access or move laterally within the network of your organization.

 Make sure you have NetFlow collectors configured. Learn more about how to configure Lumu VAs on our [NetFlow configuration guide](#).

In this article, you will find a general playbook to operate Network bruteforce incidents alongside an example scenario.

General Playbook

This is the general playbook for Network bruteforce incident operation. It covers the main steps that you can take when investigating and remediating this type of incident. The general playbook covers the three most common scenarios and actionable steps that you can take throughout to contain and remediate the incident.



Example Scenario

Now, let's delve into one of the most common scenarios that an organization can find when operating Network brute force incidents. This will help exemplify the value this feature can provide.

Let's consider a scenario where Lumu notifies that several services within an organization are being targeted by a Network brute force attack.

1. Organization A gets notified of a Network bruteforce incident coming from the **source IP 10.0.5.23**. While this alone is not a sure sign of compromise, the cybersecurity specialist must investigate further to analyze the level of compromise.

[← Go back](#)

Email Report

Export ▾

Source: 10.0.5.23

General description: East-West Brute-force detection

Network Brute-force

Collector

Virtual Appliance - Netflow

Name

va-netflow-core-01

Label

Production

STATUS: OPEN IN PROGRESS

Last operation action: Sep 02, 2025 - 09:01:28

By inspecting the incident, the specialist in charge will be able to access its details to learn more relevant information about the incident, as well as additional context to better operate it.

Brute-force Events

All events (.csv)

4
Brute Force Events

25
Target IPs

240.300
Attempts (200.3 Per second)

Target	Service	Packets	Attempts	Date ▾
255.255.255.255 Admin	LDAP TCP 389	41.200 Avg. Size 510 B	12.100 205 per second	Sep 02, 2024 08:26:23 1min 23sec
170.5.222 Admin	SMB TCP 445	44.600 Avg. Size 505 B	13.800 166 per second	Sep 02, 2024 08:25:38 1min 12sec
34.118.203.91 Admin	SSH TCP 22	38.900 Avg. Size 498 B	11.500 166 per second	Sep 02, 2024 08:24:53 58sec
88.14.77.230 Admin	LDAP UDP 3389	27.400 Avg. Size 515 B	7.900 166 per second	Sep 02, 2024 08:24:08 1min 05sec

2. With the information of the incident at hand, the cybersecurity specialist first analyzes which ports and services are being targeted to define the course of action during this procedure.

 SMB services require a thorough inspection to rule out it is not a false positive, since this service is usually used to share files across different resources of a network.

3. Having defined which are the services being targeted, the specialist researches the source IP to identify whether this device should connect to this service or it has the required permissions to connect to it. At the same time, the cybersecurity specialist verifies if the IP belongs to the organization or it comes from an external source.

 Take into consideration that a connection to an external source also indicates a security breach within your network.

4. The cybersecurity specialist identifies that the source IP of the incident is internal. Then, they proceed to review whether this behavior aligns with the network's security parameters, the company's access policies, and the configuration of the services reported in the incident. Additionally, they contact the owner of the device who reports that they were not attempting any server access and do not have any script that performs that action.

5. The specialist now reviews the source endpoint to review its activity. They found that the device has been contacting malicious infrastructure which suggests that the device has been compromised and is being used as a pivot point inside the organization's network.

6. With all this information, the cybersecurity team takes the following measures:

- Disable the service that is being targeted to prevent any further Network bruteforce attempts.
- Additionally, the team can also decide to block the source IP to prevent any further Network bruteforce attempts and disconnecting the device from the network. They could also review whether the service should be available or disable it via GPO policies.

 For the case of external attacks, cybersecurity teams can take security measures through the Firewall.

- Further investigation into the endpoint to make sure there were no successful connection attempts. In case, there were any successful connections, the incident is now escalated and handled thoroughly by the cybersecurity team to identify the data that has been compromised.
- The affected device is taken for maintenance to rid it from any possible malware. This will protect any sensible data in the device from being compromised again.

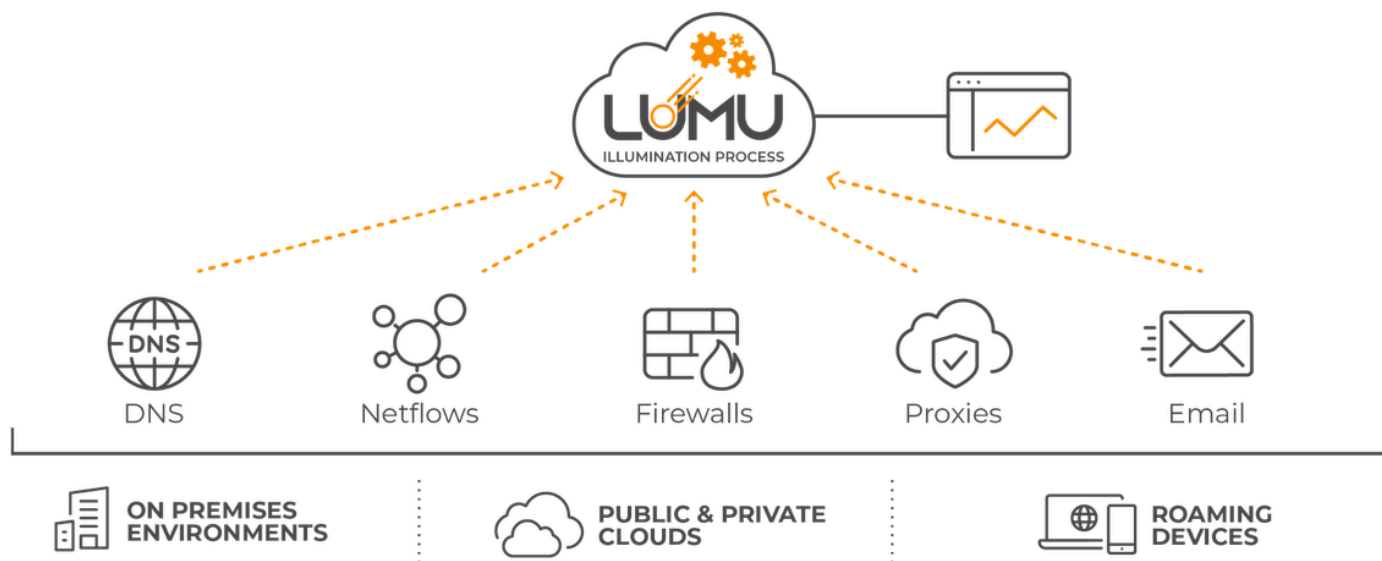
Preparation

This is the initial phase where organizations take preventive measures to respond effectively to incidents, some recommended steps to prepare your company to deal with a Network brute force incident are listed below:

- **Incident Handler Communications and Facilities:** It's vital to gather contact information of everyone involved with incident response to facilitate contact during an incident. Compile contact information of incident response (IR) team members, external IR teams, and eventually law enforcement, with primary and backup contacts. Determine the escalation and de-escalation criteria and incident reporting mechanisms, such as phone numbers, email addresses, and secure instant messaging.
- **Roles and Responsibilities:** Details of the roles and responsibilities of key individuals and teams responsible for incident response and decision-making should also be gathered at this stage.
- **Training and awareness:** Train the incident response (IR) team to identify common MITRE ATT&CK techniques used by adversaries that involve logging in to corporate accounts to damage the organization, and study possible mitigations:
- **ID: T1078 - Valid Accounts:** Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources.
- **ID: T1098 - Account manipulation:** Adversaries may manipulate accounts to maintain and/or elevate access to victim systems. Account manipulation may consist of any action that preserves or modifies adversary access to a compromised account, such as modifying credentials or permission groups.
- **ID T1110 - Brute Force:** Adversaries may use brute force techniques to gain access to accounts when passwords are unknown or when password hashes are obtained. Without knowledge of the password for an account or set of accounts, an adversary may systematically guess the password using a repetitive or iterative mechanism.
- **ID T1110.001 - Password Guessing:** Adversaries with no prior knowledge of legitimate credentials within the system or environment may guess passwords to attempt access to accounts. Without knowledge of the password for an account, an adversary may opt to systematically guess the password using a repetitive or iterative mechanism.
- **ID T1110.003 - Password Spraying:** Adversaries may use a single or small list of commonly used passwords against many different accounts to attempt to acquire valid account credentials. Password spraying uses one password (e.g. 'Password01'), or a small list of commonly used passwords, that may match the complexity policy of the domain.
- **ID T1110.004 - Credential Stuffing:** Adversaries may use credentials obtained from breach dumps of unrelated accounts to gain access to target accounts through credential overlap. Occasionally, large numbers of username and password pairs are dumped online when a website or service is compromised and the user account credentials accessed.
- **ID T1021 - Exploitation of Remote Services:** Adversaries may use Valid Accounts to log into a service that accepts remote connections, such as telnet, SSH, and VNC. The adversary may then perform actions as the logged-on user.
- **ID T1133 - External Remote Services:** Adversaries may leverage external-facing remote services to initially access and/or persist within a network. Remote services such as VPNs, Citrix, and other access mechanisms allow users to connect to internal enterprise network resources from external locations.
- **Tools and Resources:** It refers to the correct configuration of the technologies and infrastructure necessary to gain visibility, detect, analyze, and respond effectively to incidents.

How Lumu Helps

Lumu provides the ability to illuminate the blind spots in your network by providing coverage of your entire infrastructure, namely on-premises, public and private clouds, and roaming devices.



Recommended Actions

- To gain full visibility into your network, set up collectors such as Virtual Appliances, Gateways, and integrations to ensure that all your network metadata is ingested in the Lumu platform. Learn more in [our deployment guide](#). **Make sure you are collecting NetFlow data**, as this detection relies on it. You can find the instructions of how to set up a NetFlow collector in our [NetFlow configuration guide](#).
- Ensure you cover remote users in your compromise assessment. Learn more about [Lumu Agent](#) and [VPN and SDP configuration](#).
- Identify your vital assets (clients, IoT, clouds, remote devices, etc.) and [assign labels](#) to your traffic to help quickly identify the compromise distribution across your infrastructure in a way that makes sense for your organization.
- Control your attack surface by ensuring that services and connections exposed to external environments are governed by strict policies and controls. Verify that only essential services are exposed, and access is restricted to specific roles via secure, authenticated channels. Regularly monitor and enforce these measures to minimize vulnerabilities.
- Conduct regular awareness campaigns on security policies and risks employees face, and what actions to take when faced with a cyberattack.
- Keep your endpoint protection and operating systems updated.
- Implement best practices for Identity and Access Management (IAM).

Detection & Analysis

Organizations should prioritize rapid incident detection and validation to enable effective containment and eradication. Early detection limits the spread of infection and simplifies the response process. During this phase, security teams monitor and analyze alerts and data from systems, networks, and logs to identify potential incidents, understand the threat's scope, impact, and potential source, assess its severity, and gather forensic information. Proper documentation and communication are essential for successful incident response.

Some steps are listed below:

- **Alert Monitoring:** Collect and monitor data from network, host, and application logs, along with external sources like threat intelligence, to identify attack vectors and signs of potential incidents.
- **Incident Identification:** Determine whether an event qualifies as an incident or precursor by analyzing and correlating monitoring data.
- **Incident Analysis:** Classifying the incident type, incident response teams should quickly analyze and validate incidents. Once an incident is confirmed, the team conducts an initial analysis to determine its scope, including affected systems, origin, and attack methods. This analysis helps prioritize actions like containment and deeper investigation.
- **Enrichment and Investigation:** Gathering additional information (e.g., threat intelligence, forensics analysis) to understand the scope and impact. [Maltiverse by Lumu](#) is vital in this procedure.
- **Documentation:** Recording the details of the incident, timelines, and results of the analysis. An IR team that suspects an incident has occurred should immediately begin recording all facts related to the incident.

How Lumu Helps

Lumu unlocks the value of your own network metadata by implementing the concept of Continuous Compromise Assessment that provides comprehensive and detailed visibility into your network infrastructure. Lumu illuminates the various activities associated with indicators of compromise (IoCs) detected on your network and provides all the contextual information needed for in-depth analysis through the [Lumu Portal](#).

Recommended Actions

- Lumu Continuous Compromise Assessment technology provides real-time monitoring over the network and correlates network metadata information to identify anomalies and contact with malicious infrastructure, providing your organization with multiple tools to determine adverse activity on your network.
- Identify activity related to Network bruteforce incidents and attack patterns. Look for details, such as date, time, number of contacts, IPs, and domains. You have that information at a glance in the [Activity section](#) of the Lumu Portal.
- Use the IoC information provided by Lumu to check if the log files of your defensive infrastructure (e.g. endpoint protection, firewall, UTM gateway) contain this malicious communication.
- Identify the endpoints contacting the adversarial infrastructure related to Network bruteforce attack. This can be IoCs related to phishing and malware used to distribute infostealer malware for instance, and then match these with affected users. Use the [Attack Distribution feature](#) of the Lumu Portal to see how the compromise spreads inside your network.
- Identify how your assets are communicating with the adversarial infrastructure. You can use the [Lumu's Compromise Radar](#) feature to find out the frequency and behavior of malicious communication, so you can

differentiate occasional contact from persistent and automated compromises that have the power to cause harm to the organization.

- Use the threat intelligence information provided in each IOC in the Lumu Portal to enrich the context of the activity your organization is observing and, if an incident is confirmed, use it in incident documentation and analysis.
- If possible, reverse-engineer the malware in a secure environment (or sandbox) to understand its behavior and the functionality it implements.

Containment, Eradication & Recovery

This phase has two key goals: stopping the spread of the threat and preventing further damage within the network. Organizations should implement strategies and procedures based on the risk level of the detected compromise. Containment strategies will vary depending on the type of incident and must consider potential damage or theft of resources, the need for evidence preservation, service availability, and the time and resources required for effective response. Below are some steps to follow in this phase:

- **Containment:** Implement immediate actions or long-term strategies to isolate or limit the spread of the incident.
- **Eradication:** Identify the root cause of the incident and eliminate it.
- **Recovery:** Recover affected systems to a known good state and confirm normal operations, perform testing to ensure systems are no longer compromised, and prevent future incidents.

How Lumu Helps

Confirmed compromise intelligence about the compromised device helps security analysts to understand where and how to contain and eradicate the compromise.

Recommended Actions

- Lumu Defender integrates with your security stack and gives your organization the ability to orchestrate an effective automated response to contain any cyber threat, in line with your policies.
- Lumu orchestration can assist you in the containment process by blocking connections to IPs identified as malware/phishing nodes, or any type of activity related to the incident type, within your perimeter security infrastructure.
- Use the threat Intelligence information, Mitre ATT&CK TTPs, and IoCs details from [Lumu Portal](#) to configure your security infrastructure scheme (firewalls, IDS, IPS, email gateways, etc) to avoid similar malicious activity.
- Lumu Portal provides your organization with information and details about the devices or IP addresses involved in the incident to initiate targeted investigations into the related internal devices.
- Based on your containment strategy, consider isolating the affected devices to prevent lateral movement and limit the spread of the incident within the network
- Identify related services and users and reset the credentials of all involved systems.
- If you suspect the initial attack vector was via email, check the details in the organization's mail server log files.

- Remove threats, and replace or restore the compromised assets to their previous state. Wipe and baseline affected systems if needed.
- Use Lumu technology to establish monitoring to detect further suspicious activity. The incident and its effects need to be remediated across the entire network.
- Complete malware scanning of all systems across the affected network.

Post-Incident Activity

This phase is designed to incorporate the lessons learned from each incident and to evaluate future improvements.

- **Lessons Learned:** Conduct post-incident reviews to analyze the incident and determine areas for improvement. This step should answer at least the next key questions:
 - What were the root causes of the incident and the incident response issues?
 - Could the incident have been prevented? How?
 - What went well in the incident response?
 - How can we improve our response to future incidents?
- **Incident Reporting:** Document the incident and share reports with necessary stakeholders.
- **Process Improvement:** Update policies, procedures, and tools based on findings from the incident.

How Lumu Helps

Lumu helps refine your current and future defense and response by continuously monitoring that the compromise has been eradicated.

Recommended Actions

- Use Lumu Continuous Compromise Assessment to monitor continuously any communication between your assets and adversarial infrastructure to make sure that no additional contacts are reported.
- Use the [context information](#) in the Lumu Portal for details on how the adversary works. Conduct root cause analysis and evaluate the habits of the users.
- Explore the related sources, Mitre ATT&CK Matrix, and articles provided by Lumu in the [Context area](#) to understand more about the Tactics, Techniques and Procedures used by adversaries and document the incident.
- Use the incident information to adjust your security policies and Mitre Matrix context to evaluate your security strategy. This may involve changing the configuration of the company's assets and conducting awareness campaigns, focusing on the users that own those devices.
- Coordinate with your endpoint protection technology vendor's updates if needed.
- Document and share with the stakeholders all the lessons learned from the incident and recommendations of any aspect that could be improved to help prevent a similar cyber incident from reoccurring.